

Segurança em Redes de Comunicações

Security in Communications Networks

Second Project

Professors:

Paulo Salvador	salvador@ua.pt ;
Victor Marques	victor@ua.pt
Alfredo Matos	alfredo.matos@ua.pt

Objective: Create a UEBA module for a SIEM. This module should implement data analysis rules to detect anomalous network behaviors and possibly compromised devices. Test the defined rules on a data log of IP traffic flows, identifying the compromised devices.

Description:

A corporate network has a SIEM system with the historic data of traffic flows on the network. Data was received from the main firewalls logging system. To implement a reliable Cybersecurity system it requires a UEBA module able to implement alert rules for devices anomalous behaviors.

In order to simplify deployment and test, data was exported from a SIEM (e.g. ELK Elastic Search or Wazuh Indexer) to external files in JSON format as a [Pandas dataframe](#). Rules should be implemented and tested using a python script. **You do not have to implement a formal SIEM.** However, for extra points you may incorporate a UEBA report system that sends rsyslog messages/alerts to a SIEM.

Consider the dataset (datasetX.zip file) with files:

- internal_trainX.json: contains flows from internal clients. Already analyzed, can be considered anomaly free.
- internal_testX.json: contains flows from internal clients. Contains anomalies.
- external_trainX.json: contains flows from external clients. Already analyzed, can be considered anomaly free.
- external_testX.json: contains flows from external clients. Contains anomalies.

where X is the remainder of the division of the sum of the student numbers by 10. In python:

$$X = (\text{num_mec1} + \text{num_mec2}) \% 10$$

The file internal_testX contains data, from the internal devices, from a full day and may contain anomalous behaviors resulting from illicit activities, such as internal botnet activities, data exfiltration, and remote C&C of devices.

The file external_testX.json contains data from a full day of external accesses to the corporation servers (in network 200.0.0.0/24) from a small set of clients in the same external network, and may contain external users interacting with the corporation servers in an anomalous way (tip: it is not the amount of traffic or flows).

Using data from one full day (files internal_trainX and external_trainX) define the historical behavior of clients. This historical data was already fully analyzed and no illicit behavior was detected.

You may assume that the IPv4 private address of each device does not change over one day time and is assigned to the same end-user. All rules must use parameters or numeric values inferred from this data files (network historic).

Each *.json data file contains the list of all observed IPv4 data flows with the following information about each flow (columns):

- timestamp: time of observation of the first packet of the flow, in 1/100 of seconds from 0h of the day;
- src_ip: IPv4 source address (for dataX and testX files identifies the internal device, for the serversX file identifies the external client);
- dst_ip: IPv4 destination address (identifies the external or internal server);
- proto: transport protocol used (tcp or udp);
- port: destination port;qq
- up_bytes: total of uploaded bytes;
- down_bytes: total of downloaded bytes.

IMPORTANT NOTE: all public IPv4 addresses represent real networks, but (besides the flows' statistics) only the owner and location are relevant. The real purpose/services of the same are not relevant!

DO NOT PERFORM SERVICE/VULNERABILITY SCANS ON THE IPv4 ADDRESSES!

Data is structured using pandas, and stored in JSON format. See: <https://pandas.pydata.org/>. Check the provided python script (sampleScript.py) with basic examples on how to read and process the data files. Geo-localization based on the IPv4 address must rely on the db-ip geo-localization databases (<https://db-ip.com/db/download/ip-to-country-lite> and <https://db-ip.com/db/download/ip-to-asn-lite>). Download the country databases (also available in moodle) and place them on the same directory as the scrip/data files.

Check also the provided sample python script with with basic examples on how to perform data analysis, IP Geo-localization and DNS queries.

- Present a report with the proposed UEBA/SIEM rules and rule tests (identifying the devices with anomalous behaviors).
- Any tool is acceptable to identify rules thresholds and identify anomalies, however must be reported in detail!
- Submit via e-learning, in PDF format, until June 8th (inclusive).
- Should be done by a group of 2 students. Exceptionally, can be done individually.
- Tasks:
 - Analysis of the non-anomalous behaviors: (i) identify the network private IPv4 network(s), (ii) identify internal server/services, (iii) describe and quantify traffic exchanges (upload/download statistics, ratios, and destination countries) from internal users with internal and external servers, and (iv) describe and quantify traffic exchanges (overall, ratios and interval between flows) from external users with the corporation public servers.
 - Definition of the UEBA/SIEM rules and respective justification for detection of:
 - (i) internal BotNet activities (2 points),
 - (ii) data exfiltration using HTTPS and/or DNS (4 points),
 - (iii) C&C activities using DNS (2 points),
 - (iv) anomalous external destinations (2 points), and
 - (v) external users using the corporate public services in an anomalous way (2 points).
 - **UEBA rules must be well defined based on historical values from data.**
 - Test of the UEBA/SIEM rules and identify the devices (IP addresses) with anomalous behaviors.
List the IP addresses of the devices identified as anomalous in the test files. (8 points).
 - Reporting system to SIEM (1 point).
 - Written report; structure, readability and content (multiplication factor: 0% to 100%).